HORIZON VALLEY MEDICAL CENTER

Cyber Risk Report to the Board

Q4 2026 · Risk posture, financial exposure and the decisions we need

Board meeting · October 21, 2026

Presented by Denise Coleman, Security & Risk Lead · Prepared by Sabitha S Karanavar

Confidential — for board use · Lab simulation

Executive summary

Our cyber risks are known, measured and fixable — quickly and cheaply relative to the exposure.

5
High-rated risks today
→ 0 after the plan

$2.77M
Expected annual loss (top 5 risks)
→ $0.82M after the plan

6
Live automated alerts (Red)
from daily Azure checks

$52,554
Plan cost, year 1
$12,975 one-time + $39,579/yr

Key findings

- We **cannot currently detect** an intrusion — no security logs are collected.
- The EHR data store is **reachable from the internet** and could not be rolled back after ransomware.
- One person holds **all administrator access** — a single point of failure.
- An EHR outage costs ≈ **$6,884/hour**; patient safety limits downtime to **8 hours**.

What we ask today

1. Approve the 8-week mitigation plan and budget.
2. Authorize cyber-insurance procurement.
3. Designate a Privacy Officer.
4. Receive quarterly KPI reporting.

Top five risks — in plain language

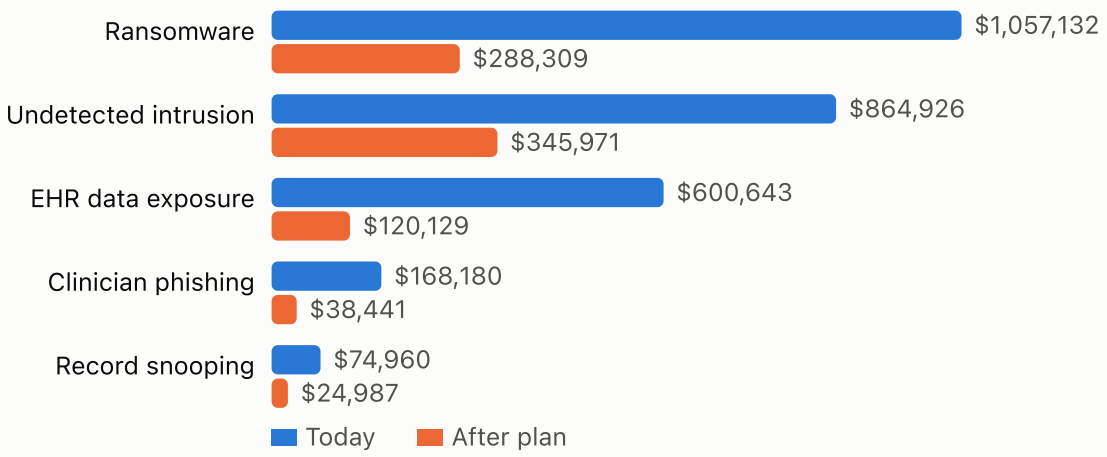
Ranked by our weighted model (operational 36%, compliance 33%, financial 19%, reputation 12%).

#	What could happen · why	Business impact	Owner	Today → after plan
R01	**An intruder could stay hidden for months** No security logs are collected or alerted on	Breach found late; biggest driver of cost	Fatima Ali	High → Medium
R05	**Ransomware could wipe EHR records** Deleted/encrypted files can't be rolled back; recovery never tested	EHR down past its 8-hour safety limit	Fatima Ali	High → Medium
R03	**An attacker on the web server could reach the database** Network zones aren't sealed off from each other	Theft or tampering with lab/medication data	Fatima Ali	High → Low
R10	**Old internet-facing server has known flaws** 2014 software with public exploits	Foothold for attackers (no patient data on it)	Kevin O'Brien	High → Eliminated
R02	**Patient files reachable from the internet** EHR storage open to public networks with shared keys	Large reportable breach; regulator action	Fatima Ali	High → Low

Financial impact

Each dollar of controls removes far more expected loss; insurance covers what remains.

Expected annual loss — today vs after plan



The numbers

Expected annual loss, top 5 risks	**$2,765,843 → $817,836**
Reduction	**$1,948,007** per year
Plan cost	$12,975 one-time + $39,579/yr
Cyber insurance (in plan)	$25,000/yr, $5.00M limit
EHR downtime cost	$6,884/hour · $80,075 at 8 h
Identity (Entra ID) outage	$12,577/hour — every system stops

Loss model: IBM 2025 healthcare breach cost + HIPAA annual penalty cap; hospital financials are planning assumptions. Even if losses were 10× smaller, every control pays back.

Where we are exposed

Exposure concentrates on the patient-data store, the EHR, and the identity system everything depends on.

Critical asset	Exposure	Linked risks	Who depends on it
hvmcehrstorage Tier 1 · ePHI data store (Azure Storage)	▲ High	R02, R05, R07, R11	EHR, Nurse read-only role
EHR application Tier 1 · Clinical system	▲ High	R03, R05, R12, R13	Clinicians (12), LIS, Pharmacy, Scheduling
HVMC-Prod-VNet — Data subnet Tier 1 · Network segment 10.0.3.0/24	▲ High	R03, R15	EHR database (SQL 1433)
Pharmacy Management System Tier 1 · Clinical system	▲ High	R03, R13	Pharmacists (3), nursing medication administration

Single points of failure: Entra ID (one administrator), the Data network zone, one Azure region for compute, and no central logging.

Recommendations

Eight actions, owned and dated. Items 1–3 are configuration changes that clear three of the six Red alerts within two weeks.

#	Action	Ref	Owner	Due	Cost (yr 1)	Effect
1	**Seal the patient-data store and network zones**	C02, C03	Fatima Ali	Oct 25	$1,890	R02, R03 → Low
2	**Fix the single-administrator weakness**	C04	Sabitha S Karanavar	Oct 25	$816	R04 → Low
3	**Retire the old public server and test account**	C13, C14	Kevin O'Brien	Nov 1	$600	R07, R09, R10 eliminated
4	**Turn on security logging and alerts**	C01	Fatima Ali	Nov 15	$2,131	R01 High → Medium
5	**Make EHR data recoverable; test restore to 4 h**	C05	Fatima Ali	Nov 22	$3,600	R05 High → Medium
6	**Phishing-resistant sign-in for clinicians**	C07	Sabitha S Karanavar	Dec 13	$3,432	R12 → Low
7	**Name a Privacy Officer; breach procedure**	C11	Denise Coleman	Dec 6	$6,200	R16 → Low
8	**Buy cyber insurance once controls are in**	T01	Brian Adeyemi	Dec 13	$25,600	Caps financial tail of R02/R05

Roadmap — 8 weeks

Completion December 13, 2026; progress reported monthly to the Executive Risk Committee.

Phase 1 · Oct 19 – Nov 1

Quick wins & eliminations

Storage lockdown, network seal, admin resilience, tenant hardening, retire legacy server & test account, contractor BAA

Phase 2 · Nov 2 – Nov 22

Detect & recover

Logging and alerts, ransomware-resilient backups with restore drill, malware scanning, sanction policy & training

Phase 3 · Nov 16 – Dec 13

Identity, auditing & transfer

Phishing-resistant sign-in, EHR access auditing, Privacy Officer, cyber insurance

Resources

- 153 staff hours across 7 owners (largest: Fatima Ali, ~8–10 h/week)
- Licences: Entra ID P1/P2, Defender for Storage, Log Analytics
- Legal review of contractor BAA; insurance broker

Residual risk after the plan

- High risks: **5 → 0**; 3 risks eliminated
- Two Medium residuals (detection, ransomware) for owner acceptance
- All others Low and within appetite

Decisions requested

Please confirm the following resolutions.

1	**Approve** the mitigation plan and year-1 budget of $52,554 ($12,975 one-time; $39,579 recurring).	☐ Approved
2	**Authorize** the CFO to procure cyber-liability insurance (≈ $5M limit) after Phase 2 controls are verified.	☐ Approved
3	**Designate** a Privacy Officer by December 6, as required by HIPAA.	☐ Approved
4	**Delegate** acceptance of the two Medium residual risks (R01, R05) to the Executive Risk Committee once controls are tested.	☐ Approved
5	**Endorse** quarterly board reporting on the six KPIs on the next slide.	☐ Approved

What the board will see each quarter

Leading indicators show whether we are doing the work; lagging indicators show whether risk is falling.

Indicator	Today	Dec target	Green / Amber / Red
L1 Mitigation controls implemented Leading indicator · Denise Coleman	0%	88%	G ≥ plan · A within 10 pts · R > 10 pts behind
L2 KRIs at Green Leading indicator · Anthony Ruiz	0%	80%	G ≥ 90% · A 60–89% · R < 60%
L4 Phishing-resistant MFA coverage Leading indicator · Sabitha S Karanavar	—	60%	G ≥ 90% · A 60–89% · R < 60%
G1 High or Critical risks Lagging indicator · Denise Coleman	5	1	G 0 · A 1–2 · R ≥ 3
G2 Expected annual loss (top 5) Lagging indicator · Brian Adeyemi	$2.77M	$1.10M	G ≤ $1M · A $1–2M · R > $2M
G3 Open HIPAA gaps Lagging indicator · Denise Coleman	8	1	G 0 · A 1–3 · R ≥ 4

Live detail: HVMC Risk Dashboard (drill-down from any figure to the underlying risk, asset and evidence). Automated KRIs refresh daily from Azure.

Appendix — method and sources

- **Framework:** NIST RMF with ISO 31000 principles; controls mapped to NIST CSF 2.0 and ISO/IEC 27001:2022 Annex A.
- **Risk scoring:** likelihood × weighted impact (financial, operational, compliance, reputation); weights by AHP (consistency ratio 0.017).
- **Financial model:** ALE = SLE × ARO; asset value from IBM Cost of a Data Breach 2025 (healthcare $7.42M) + HHS 2025 HIPAA annual cap ($2,190,294); hospital revenue and tolerances are planning assumptions.
- **Business impact:** NIST SP 800-34 BIA — MTD = min(financial tolerance, patient-safety limit, policy); RTO and RPO derived.
- **Evidence:** live read-only Azure CLI checks of the HVMC subscription and Entra ID tenant (kri_monitor.py).
- **Supporting documents:** Risk Management Fundamentals · Risk Assessment Techniques · Risk Evaluation Methods · Risk Mitigation Planning · Risk Register.